

恶意代码分析与防治技术实验报告

实验三



网络空间安全学院

信息安全专业

2211985 李佳璐

一、实验目的

1. 使用动态分析技术完成对给定病毒样本的分析；
2. 熟悉虚拟机、Yara等的操作。

二、实验原理

为了保护本机免受恶意代码攻击，本次实验主体在虚拟机上完成，以下为相关环境：

- 1. 已关闭病毒防护的Windows11
- 2. 在VMware上部署的Windows XP虚拟机

三、实验过程

Lab03-01.exe

问题：

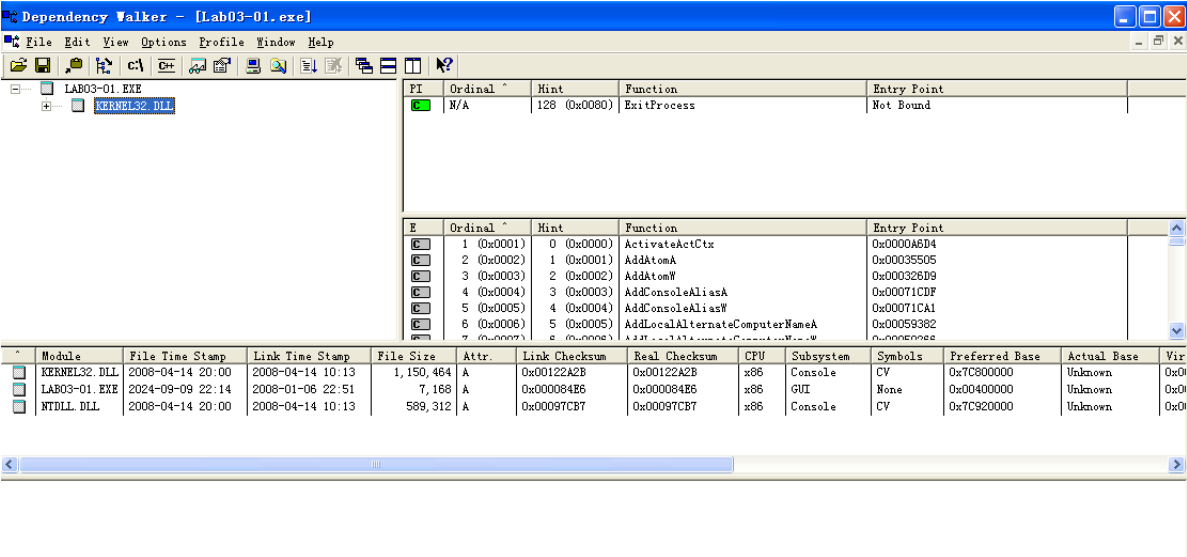
使用动态分析基础技术来分析在Lab03-01.exe文件中发现的恶意代码。

- 1. 找出这个恶意代码的导入函数与字符串列表？
这个恶意代码看起来是被加过壳的。使用Dependency Walker工具可见唯一的导入函数是ExitProcess，虽然出现字符串大多是明文，而未被混淆过。
- 2. 这个恶意代码在主机上的感染迹象特征是什么？
使用Process Explorer可见该恶意代码创建了一个名为winvmx32的互斥量，并复制自身到C:\Windows\System32\vmx32to64.exe，并安装自己到系统自启动项中，通过创建注册表键值HKLMSOFTWARE\Microsoft\windows\CurrentVersion\Run\VideoDriver，并将其设置为复制副本的位置。
- 3. 这个恶意代码是否存在一些有用的网络特征码？如果存在，它们是什么？
进一步使用Wireshark等工具，发现恶意代码在进行www.practicalmalwareanalysis.com的域名解析后，持续地广播大小为256字节的数据包，其中包含看似随机的二进制数据。

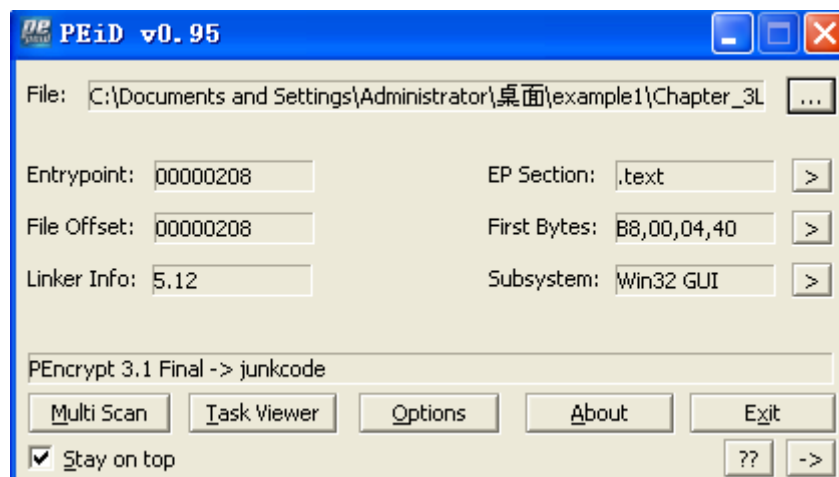
具体解析过程如下：

• 静态分析

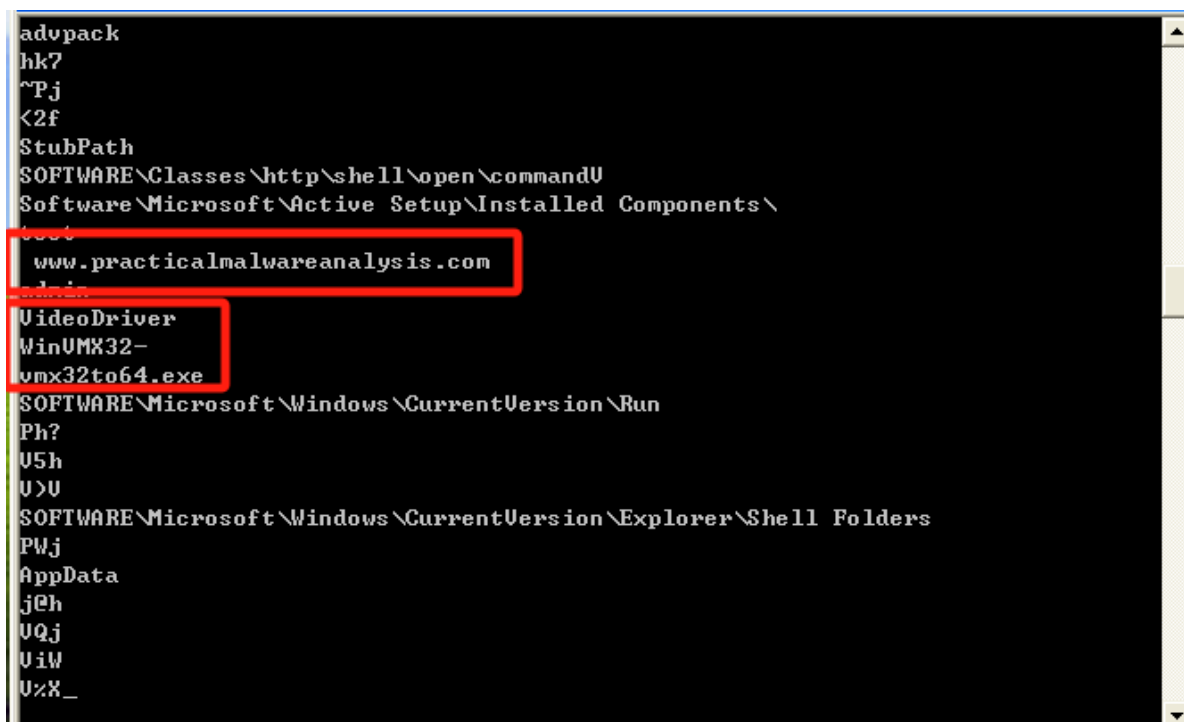
使用Dependency Walker打开文件，查看其导入函数。可以看到，仅有一个ExitProcess。而单凭这一个函数无法使这个程序正常运行，怀疑该文件出现了加壳。



使用PEID打开，检测加壳信息。如图所示，可见为PEncript 3.1 Final -> junkcode 加壳



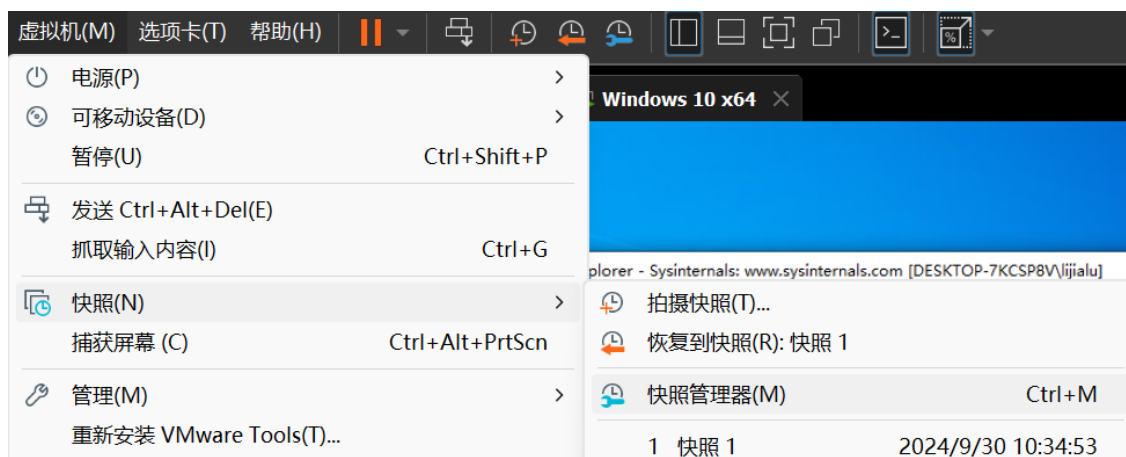
使用string试图查看字符串，因为加壳，预期是看不到明文字符串的。但发现了可能暗示恶意代码功能的字符串，比如注册表位置、域名、WinVMX32、VideoDriver、vmx32to64.exe。



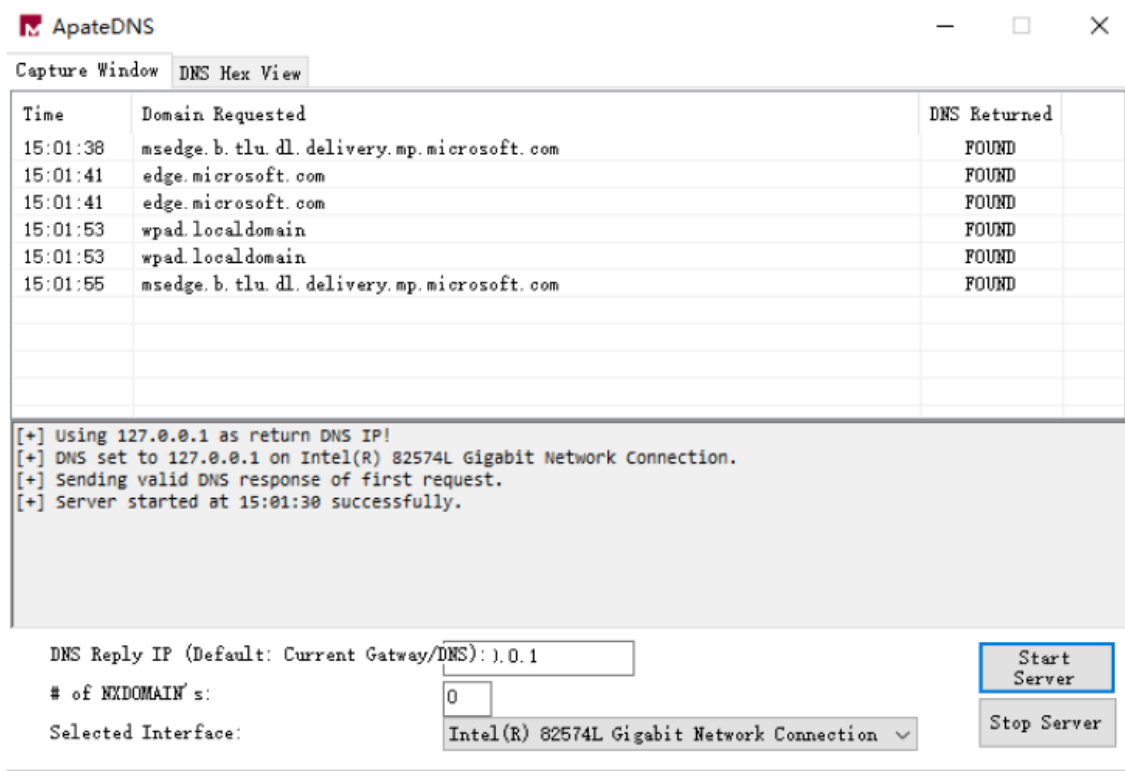
• 动态分析

在进行动态分析时，需对虚拟机做如下处理：

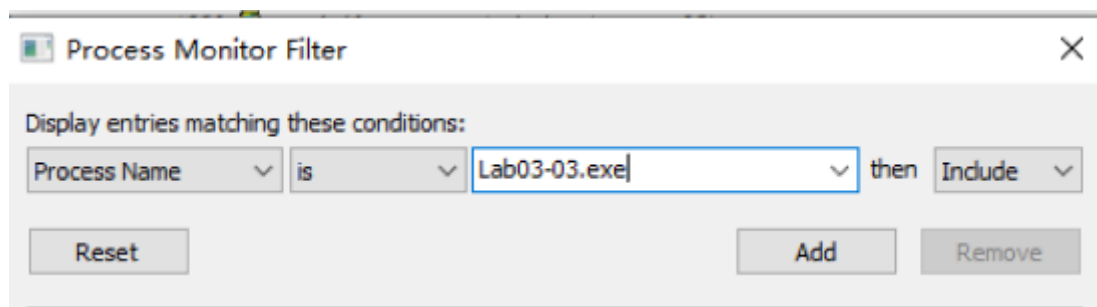
1. 对VMware进行快照，便于恢复到运行前的状态



2. 启动ApateDNS，将DNS Reply IP设置为127.0.0.1

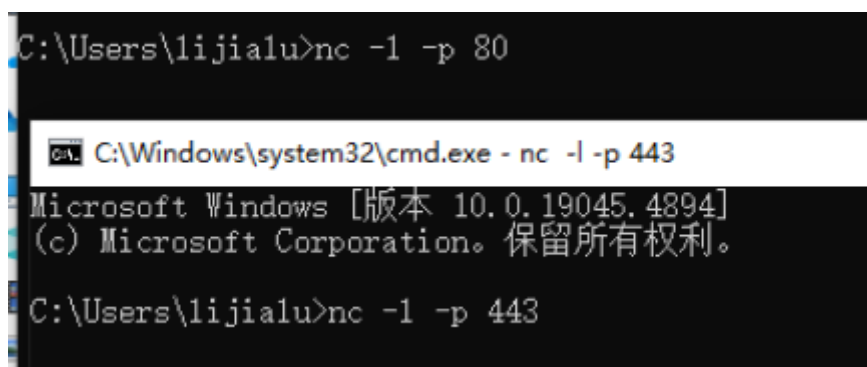


3. 启动Process Monitor，并按照实验要求设置过滤条件



4. 启动Process Explorer

5. 启动netcat: nc -l -p XXX，监听端口80和443



6. 启动wireShark抓取数据包

运行恶意代码后，在Process Explorer中检查进程。

单击Lab03-01.exe进程项目和选择 View → Lower Pane View → Handles。在这个视图中，可以看到，恶意代码已经创建了一个名为WinVMX32的互斥量。

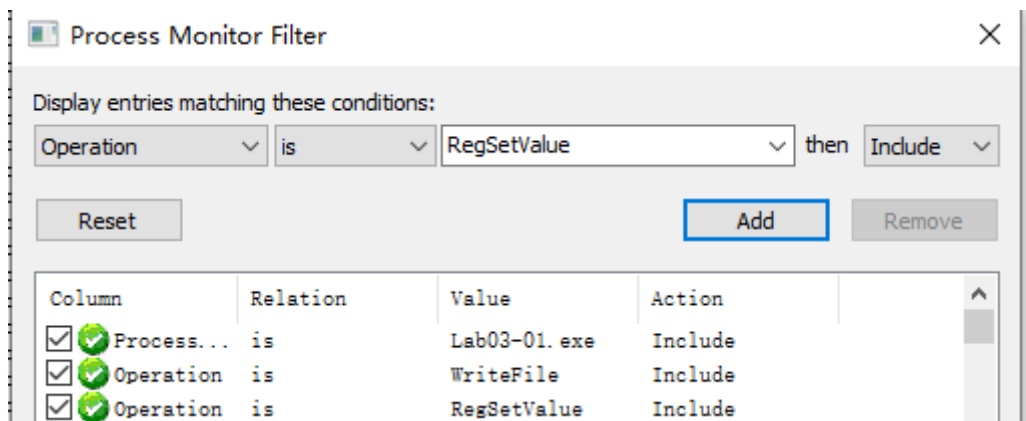
Type	Name
Desktop	\Default
Directory	\KnownDlls
Directory	\Windows
Directory	\BaseNamedObjects
File	C:\Documents and Settings\Administrator\桌面\恶感代码\上机实验样本\Chapte...
File	\Device\KsecDD
File	\Device\Tcp
File	\Device\Tcp
File	\Device\Ip
File	\Device\Ip
File	\Device\Ip
File	\Device\Tcp
Key	HKL\M
Key	HKL\M\SYSTEM\ControlSet001\Services\WinSock2\Parameters\Protocol_Catalog9
Key	HKL\M\SYSTEM\ControlSet001\Services\WinSock2\Parameters\NameSpace_Catalog5
Key	HKL\M\SYSTEM\ControlSet001\Services\Tcpip\Linkage
Key	HKL\M\SYSTEM\ControlSet001\Services\Tcpip\Parameters
Key	HKL\M\SYSTEM\ControlSet001\Services\NetBT\Parameters\Interfaces
Key	HKL\M\SYSTEM\ControlSet001\Services\NetBT\Parameters
Mutant	\BaseNamedObjects\WinVNC32
Thread	Lab03-01.exe(1956): 6012
WindowStation	\Windows\WindowStations\WinSta0
WindowStation	\Windows\WindowStations\WinSta0

另外选择 View → Lower Pane View → DLL, 看到恶意代码动态装载的 DLL 文件, 如 ws2_32.dll 和 wshtcpip.dll, 这意味着它具有联网功能。

Name	Description	Company Name	Path
imm32.dll	Windows XP IMM32 API Client...	Microsoft Corporation	C:\WINDOWS\system32\imm32.dll
iphlpapi.dll	IP Helper API	Microsoft Corporation	C:\WINDOWS\system32\iphlpapi.dll
kernel32.dll	Windows NT BASE API Client...	Microsoft Corporation	C:\WINDOWS\system32\kernel32.dll
Lab03-01.exe			C:\Documents and Settings\Administrator\桌面\...
locale.nls			C:\WINDOWS\system32\locale.nls
lpk.dll	Language Pack	Microsoft Corporation	C:\WINDOWS\system32\lpk.dll
msvcrt.dll	Windows NT CRT DLL	Microsoft Corporation	C:\WINDOWS\system32\msvcrt.dll
mswsock.dll	Microsoft Windows Sockets ...	Microsoft Corporation	C:\WINDOWS\system32\mswsock.dll
ntdll.dll	NT Layer DLL	Microsoft Corporation	C:\WINDOWS\system32\ntdll.dll
ole32.dll	Microsoft OLE for Windows	Microsoft Corporation	C:\WINDOWS\system32\ole32.dll
rasadhlp.dll	Remote Access AutoDial Helper	Microsoft Corporation	C:\WINDOWS\system32\rasadhlp.dll
rpcrt4.dll	Remote Procedure Call Runtime	Microsoft Corporation	C:\WINDOWS\system32\rpcrt4.dll
secur32.dll	Security Support Provider ...	Microsoft Corporation	C:\WINDOWS\system32\secur32.dll
setupapi.dll	Windows Setup API	Microsoft Corporation	C:\WINDOWS\system32\setupapi.dll
sortkey.nls			C:\WINDOWS\system32\sortkey.nls
sorttbls.nls			C:\WINDOWS\system32\sorttbls.nls
unicode.nls			C:\WINDOWS\system32\unicode.nls
user32.dll	Windows XP USER API Client...	Microsoft Corporation	C:\WINDOWS\system32\user32.dll
usp10.dll	Unsubscribe Unicode script p...	Microsoft Corporation	C:\WINDOWS\system32\usp10.dll
version.dll	Version Checking and File ...	Microsoft Corporation	C:\WINDOWS\system32\version.dll
winmr.dll	LDAP RnR Provider DLL	Microsoft Corporation	C:\WINDOWS\system32\winmr.dll
wildp32.dll	Win32 LDAP API DLL	Microsoft Corporation	C:\WINDOWS\system32\wildp32.dll
ws2_32.dll	Windows Socket 2.0 32-Bit DLL	Microsoft Corporation	C:\WINDOWS\system32\ws2_32.dll
ws2help.dll	Windows Socket 2.0 Helper ...	Microsoft Corporation	C:\WINDOWS\system32\ws2help.dll
wshtcpip.dll	Windows Sockets Helper DLL	Microsoft Corporation	C:\WINDOWS\system32\wshtcpip.dll
wshtcpip.dll	Windows Sockets Helper DLL	Microsoft Corporation	C:\WINDOWS\system32\wshtcpip.dll

使用procmon工具寻找额外的信息。

设置三个过滤器:一个是对进程名称的过滤(显示Lab03-01.exe对系统所做的),和两个操作上的过滤。包含了RegSetValue和writeFile, 来查看恶意代码对文件系统和注册表的修改操作。



设置完过滤器之后，单击Apply按钮，便可看到过滤后的结果。显示的条目从数千减少到只有10条。只有一个WriteFile操作的条目，并有9个关于RegSetValue操作的条目。

Process Monitor - Sysinternals: www.sysinternals.com						
File Edit Event Filter Tools Options Help						
Time	Process Name	PID	Operation	Path	Result	Detail
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...
16:3...	Lab03-01.exe	2580	WriteFile	C:\WINDOWS\system32\vmx32to64.exe	SUCCESS	Offset: 0, Le...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Window...	SUCCESS	Type: REG_SZ...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...
16:3...	Lab03-01.exe	2580	RegSetValue	HKLM\SOFTWARE\Microsoft\Crypto...	SUCCESS	Type: REG_BIN...

除红框两项，其余项 HKLM\SOFTWARE\Microsoft\cryptography\ RNG\Seed 键值上的 RegSetValue 操作是典型的噪声，因为随机数发生器的种子会有软件在注册表中不停地更新。

其余其中一项是writeFile操作。双击该条目，显示记录会告诉我们，恶意代码往

C:\WINDOWS\System32\vmx32to64.exe 中写了7168字节。这恰好是 Lab03-01.exe 文件的大小。

16:3...

Lab03-01.exe

2580

WriteFile

C:\WINDOWS\system32\vmx32to64.exe

SUCCESS

Offset: 0, L

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Window...

SUCCESS

Type: REG_SZ

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

16:3...

Lab03-01.exe

2580

RegSetValue

HKLM\SOFTWARE\Microsoft\Crypto...

SUCCESS

Type: REG_BIN

Event Properties

Event

Process

Stack

Date:

2023-9-24 16:34:38.1180978

Thread:

2688

Class:

File System

Operation:

WriteFile

Result:

SUCCESS

Path:

C:\WINDOWS\system32\vmx32to64.exe

Duration:

0.0003865

Offset:

0

Length:

7,168

打开Windows资源管理器浏览到这个位置，使用virustotal查看对比 Lab03-01.exe 和 vmx32to64.exe：

eb84360ca4e33b8bb60df47ab5ce962501ef3420bc7aab90655fd507d2ffcedd

68

/73

Community Score

-183

68/73 security vendors flagged this file as malicious

eb84360ca4e33b8bb60df47ab5ce962501ef3420bc7aab90655fd507d2ffcedd

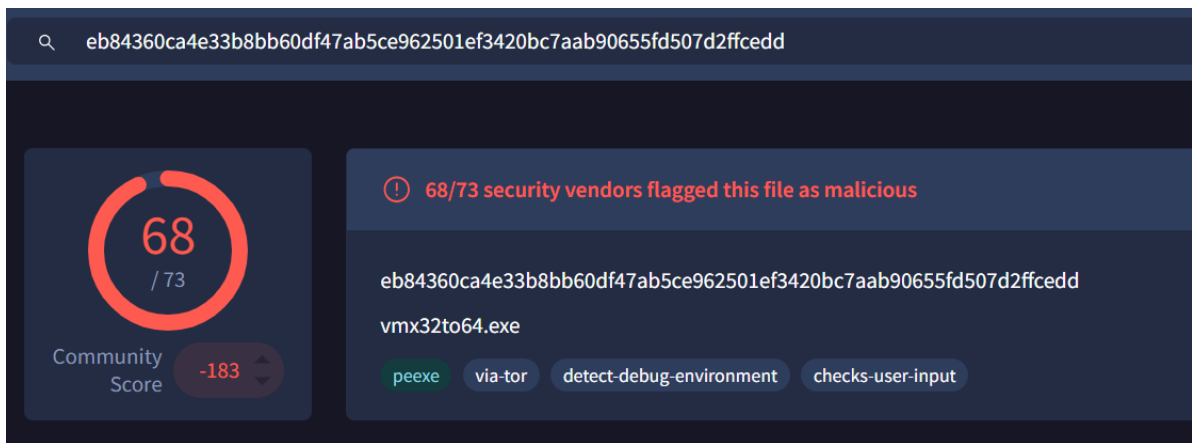
Lab03-01.exe

peexe

via-tor

detect-debug-environment

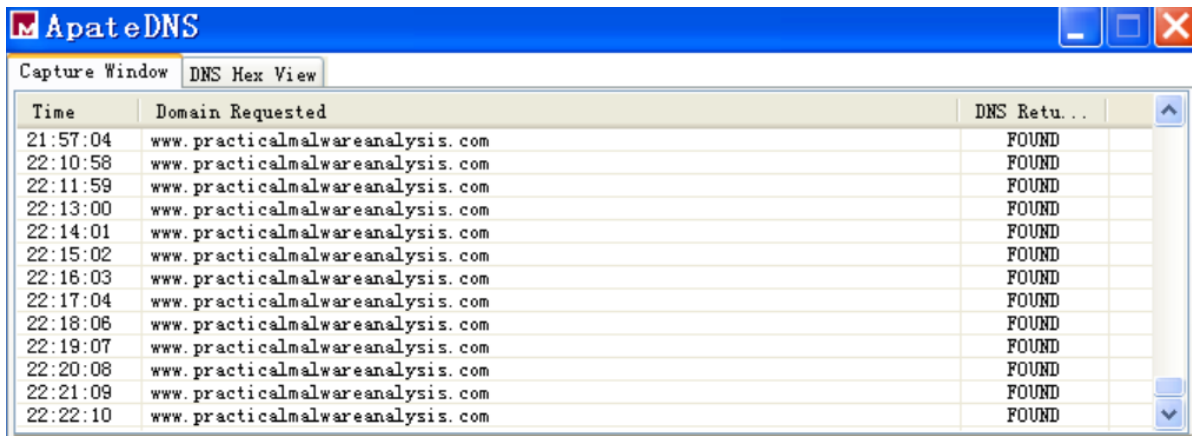
checks-user-input



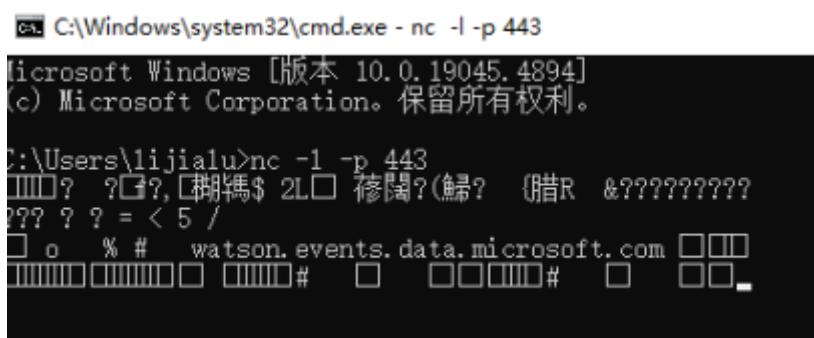
可以看到这个新创建的文件有着与Lab03-01.exe相同的MD5哈希值，两者分析结果没有差别。可以看出该恶意代码已经复制本身到这个文件系统位置上。这是一个非常有用的感染主机迹象特征，因为它使用了一个硬编码的文件名。

另外一项RegSetValue可见文件还将数据写入注册表项，命名为VideoDriver。分析可知，该文件将vmx32to64.exe写入到了开机启动的项目中。

检查ApateDNS，来查看恶意代码是否执行了DNS请求。通过检查输出，我们看到了一个对www.practicalmalwareanalysis.com域名的请求，这匹配到了字符串列表中的显示。



检查Netcat的结果来完成网络分析过程



恶意代码看起来在443端口上发出了一些信号（正在使用Netcat监听着80和443端口），多次运行这个测试，每次的数据看起来都是随机的。

对Wireshark结果的后续分析可见，这些信号数据包是固定长度的(256字节)，看起来包含的是一些随机数据，而与普通在443端口上跑的SSL协议没有关联。

Capturing from 本地连接 [Wireshark 1.12.12 (v1.12.12-0-g2f634e8 from master-1.12)]

File Edit View Go Capture Analyze Statistics Telephony Tools Internals Help

Filter: Expression... Clear Apply Save

No.	Time	Source	Destination	Protocol	Length	Info
65	44.7128720	3.33.251.168	192.168.254.129	TCP	60	443-1334 [ACK] Seq=2 Ack=258 win=64239 Len=0
66	68.9083210	192.168.254.128	192.168.254.255	BROWSE	243	Local Master Announcement DESKTOP-7KCSP8V, Workstation, Server
67	74.7034330	192.168.254.129	192.168.254.2	DNS	92	Standard query 0x6a75 A www.practicalmalwareanalysis.com
68	74.7058700	192.168.254.129	192.168.254.2	DNS	138	Standard query response 0x6a75 CNAME practicalmalwareanalysis
69	74.7065810	192.168.254.129	3.33.251.168	TCP	62	1335-443 [SYN] Seq=0 win=64240 Len=0 MSS=1460 SACK_PERM=1
70	74.7941890	3.33.251.168	192.168.254.129	TCP	60	443-1335 [SYN, ACK] Seq=0 Ack=1 win=64240 Len=0 MSS=1460
71	74.7942750	192.168.254.129	3.33.251.168	TCP	54	1336-443 [ACK] Seq=1 Ack=1 win=64240 Len=0
72	74.7945180	192.168.254.129	3.33.251.168	SSL	310	Continuation Data
73	74.7949270	3.33.251.168	192.168.254.129	TCP	60	443-1335 [ACK] Seq=1 Ack=257 win=64240 Len=0
74	75.2297740	3.33.251.168	192.168.254.129	TCP	60	443-1335 [FIN, PSH, ACK] Seq=1 Ack=257 win=64240 Len=0
75	75.2298090	192.168.254.129	3.33.251.168	TCP	54	1335-443 [ACK] Seq=257 Ack=2 win=64240 Len=0
76	75.2298950	192.168.254.129	3.33.251.168	TCP	54	1335-443 [FIN, ACK] Seq=257 Ack=2 win=64240 Len=0
77	75.2299830	3.33.251.168	192.168.254.129	TCP	60	443-1335 [ACK] Seq=2 Ack=258 win=64239 Len=0
78	105.218919	192.168.254.129	192.168.254.2	DNS	92	Standard query 0x1505 A www.practicalmalwareanalysis.com
79	105.220832	192.168.254.2	192.168.254.129	DNS	138	Standard query response 0x1505 CNAME practicalmalwareanalysis
80	105.221068	192.168.254.129	3.33.251.168	TCP	62	1336-443 [SYN] Seq=0 win=64240 Len=0 MSS=1460 SACK_PERM=1
81	105.309631	3.33.251.168	192.168.254.129	TCP	60	443-1336 [SYN, ACK] Seq=0 Ack=1 win=64240 Len=0 MSS=1460
82	105.309700	192.168.254.129	3.33.251.168	TCP	54	1336-443 [ACK] Seq=1 Ack=1 win=64240 Len=0
83	105.309876	192.168.254.129	3.33.251.168	SSL	310	Continuation Data
84	105.310544	3.33.251.168	192.168.254.129	TCP	60	443-1336 [ACK] Seq=1 Ack=257 win=64240 Len=0
85	105.747433	3.33.251.168	192.168.254.129	TCP	60	443-1336 [FIN, PSH, ACK] Seq=1 Ack=257 win=64240 Len=0
86	105.747526	192.168.254.129	3.33.251.168	TCP	54	1336-443 [ACK] Seq=257 Ack=2 win=64240 Len=0
87	105.747767	192.168.254.129	3.33.251.168	TCP	54	1336-443 [FIN, ACK] Seq=257 Ack=2 win=64240 Len=0
88	105.748184	3.33.251.168	192.168.254.129	TCP	60	443-1336 [ACK] Seq=2 Ack=258 win=64239 Len=0

Frame 72: 310 bytes on wire (2480 bits), 310 bytes captured (2480 bits) on interface 0
Ethernet II, Src: VMware_bf:20:64:00:00:29:bf:20:64, Dst: VMware_e3:0b:40:00:50:56:e3:0b:40
Internet Protocol Version 4, Src: 192.168.254.129 (192.168.254.129), Dst: 3.33.251.168 (3.33.251.168)
Transmission Control Protocol, Src Port: 1335 (1335), Dst Port: 443 (443), Seq: 1, Ack: 1, Len: 256
Secure Sockets Layer

0000 00 50 56 e3 0b 40 00 0c 29 bf 20 64 08 00 45 00 .PV..@..).d..E.
0010 01 28 07 6c 40 00 80 06 34 70 c0 a8 fe 81 03 21 .(.l@...4p....!
0020 fb a8 05 37 01 bb 82 16 e0 ae 4a 07 06 4f 50 18 ...7....j..OP.
0030 fa f0 05 b2 00 0c 27 84 f6 23 80 9d a7 d0 6e#...n
0040 97 66 ce 17 7a a0 ea 57 78 27 5a 31 72 b6 ed 40 .f..z..w x'Zlr..@
0050 9a 4a 8c 60 25 e3 2f b9 ae 88 30 d7 e6 25 cb 04 ...%./...0..%..
0060 34 ab 81 09 83 82 87 72 2d 4d d8 fc 57 c2 4e 03 4.....r-M..w.N.
0070 9b 41 3e f4 4f 7a b1 6b 78 b3 e2 90 be f9 b0 6b .A>.Oz.k x.....k
0080 e8 42 8f 9c b7 82 57 b0 ae 4b 42 5b 91 5d 97 d2 .B...w..KB[...
0090 b3 d3 ce 05 56 fc 82 99 be 3f 27 55 a8 92 1c b0V...?'U...
00a0 59 c9 26 1c 88 5b ca a4 5d e3 85 c2 ac 3c 74 14 Y.&.[.]...<t.
00b0 64 0c f9 13 a7 62 b7 2f 88 14 15 f2 bd 6b 6f e0 d...b./.....ko.
00c0 8c 97 6f b7 02 7a a0 61 c2 6e 6c a0 fb 29 19 2e ..o..z.a.nl)...
00d0 6b 58 72 a7 39 02 46 86 aa c4 29 d5 1b 53 87 3c kxr.9.F...).S.<
00e0 0f 7d 3e 18 70 04 77 64 4e 0e 37 5c 5c 4c 5c ..f..d..cm

本地连接: alive capture in progress File: ... Packets: 88 - Discovered: 88 (100.0%)

Lab03-02.dll

问题：

使用动态分析基础技术来分析在Lab03-02.dll文件中发现的恶意代码

1. 你怎样才能让这个恶意代码自行安装？

利用 rundll32.exe 工具，使用命令 rundll32.exe Lab03-02.dll,installA，运行恶意代码导出的 installA 函数，便可将恶意代码安装为一个服务。

2. 在安装之后，你如何让这个恶意代码运行起来？

使用net命令执行 net start IPRIP，便可启动恶意代码安装的服务。

3. 你怎么能找到这个恶意代码是在哪个进程下运行的？

使用ProcessExplorer的 Find dll 功能来搜索 Lab03-02.dll，可以看到该恶意代码是在 svchost.exe进程下运行的。

4. 你可以在 procmon 工具中设置什么样的过滤器，才能收集这个恶意代码的信息？

在procmon工具中，可以使用上题中在Process Explorer 发现的 PID 进行过滤。

5. 这个恶意代码在主机上的感染迹象特征是什么？

默认情况下，恶意代码将安装为IPRIP服务，显示的服务名称为

IntranetNetworkAwareness(INA+)，描述为 “Depends INA+, Collects and stores network configuration and location information, and notifies applications when this information changes” 它将自身持久地安装在注册表中 HKLM\SYSTEM CurrentControlSet Services

IPRIP\Parameters\ServiceDll:%CurrentDirectory%Lab03-02.dll。如果将Lab03-02.dll 重命名为其他文件名，如 maware.dll，然后这个恶意代码就会把 malware.dll 写入到注册表项中，而不是使用名称 Lab03-02.dll。

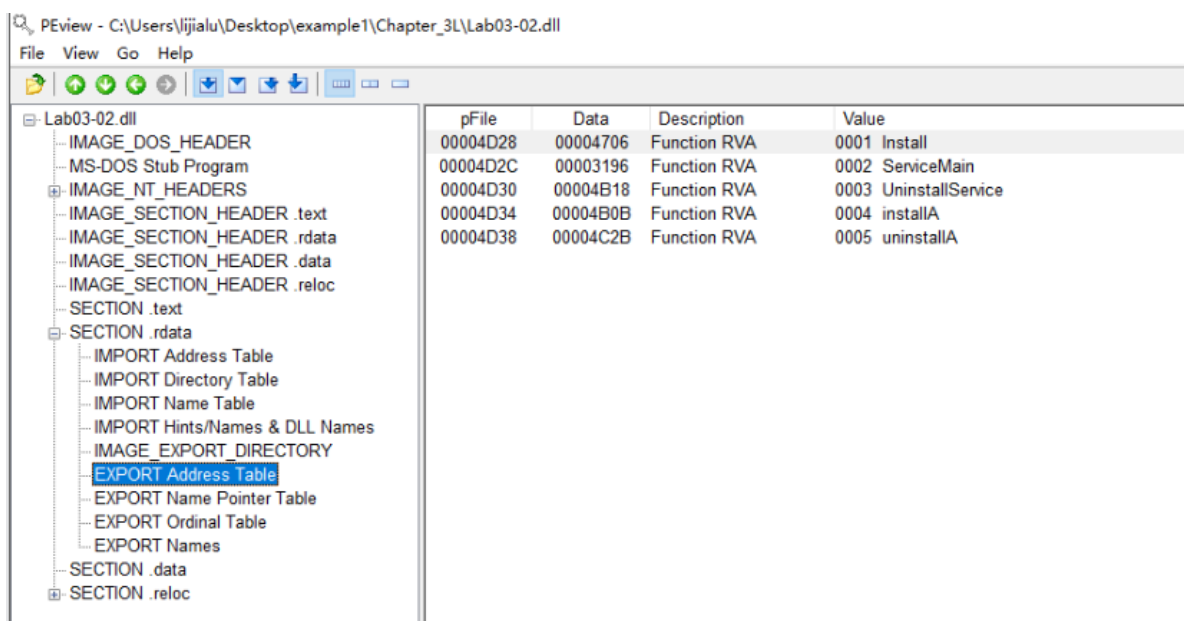
6. 这个恶意代码是否存在一些有用的网络特征码？

恶意代码申请解析域名 `practicalmalwareanalysis.com`，然后通过80端口连接到这台主机，使用的协议是HTTP协议。它在做一个GET请求 `serve.html`，使用的用户代理为 `de11-cdce31a6e0 windows XP6.11`。

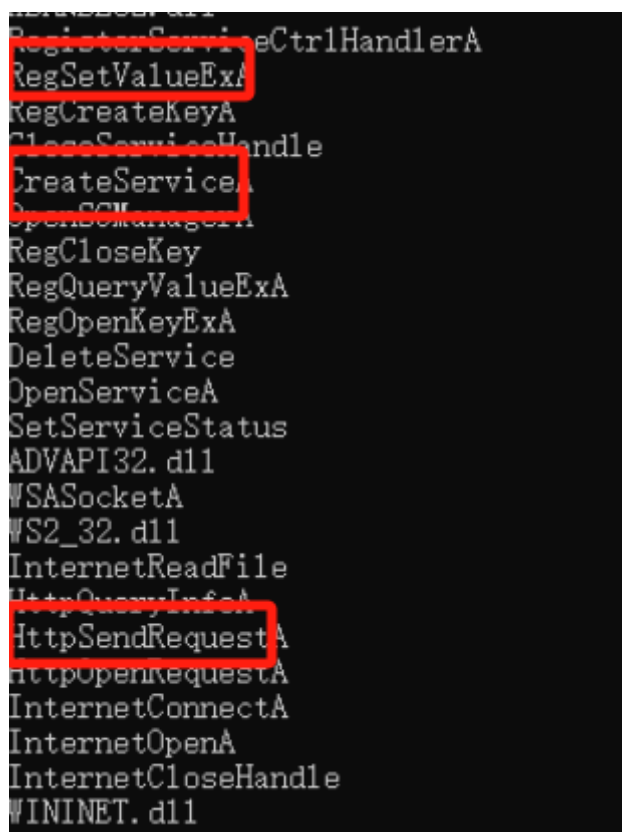
具体解析过程如下：

• 静态分析

使用PEview工具查看这个样本的PE文件结构，可见这个DLL有五个导出函数。从导出函数ServiceMain表明，这个恶意代码需要安装成一个服务，使其能够正常运行。



使用strings工具查看字符串，其中包含恶意代码的导入函数，这里包括了一些服务操作函数，比如 `CreateService`，以及一些注册表操作函数，如函数 `RegSetValueEx`。导入的网络操作函数，如 `HttpSendRequest` 等，表明恶意代码使用了HTTP。



此外，还可以看到一些字符串，包括注册表位置、域名、一些独特的字符串如 IPRIP 和 serve.html，以及一些编码的字符串。

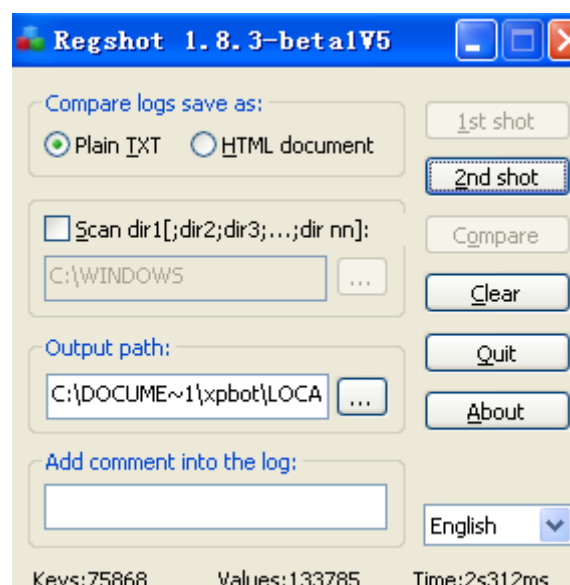
```
C:\Windows\system32\cmd.exe
Parameters
Type
Start
ObjectName
LocalSystem
ErrorControl
DisplayName
Description
Depends INA+, Collects and stores network configuration and location information, and notifies
formation changes.
ImagePath
%SystemRoot%\System32\svchost.exe -k
SYSTEM\CurrentControlSet\Services\
CreateService(%s) error %d
Intranet Network Awareness (INA+)
%SystemRoot%\System32\svchost.exe -k netsvcs
openSCManager()
You specify service name not in Svchost//netsvcs, must be one of following:
RegQueryValueEx(Svchost\netsvcs)
netsvcs
RegOpenKeyEx(%s) KEY_QUERY_VALUE success.
RegOpenKeyEx(%s) KEY_QUERY_VALUE error .
SOFTWARE\Microsoft\Windows NT\CurrentVersion\Svchost
IPRIP
uninstall success
OpenService(%s) error 2
OpenService(%s) error 1
uninstall is starting
. ?Avtype_info@@
08000 0m0r0
```

• 动态分析

将恶意代码安装为服务

静态分析基础技术的结果可知这个恶意代码需要使用导出函数installA将自身注册为一个服务。

故使用这个函数来试图安装恶意代码，在做安装恶意代码之前，需使用Regshot工具，来对注册表做个基线快照。



并且使用Process Explorer来监控在系统上运行的进程。

当我们设置好Regshot和Process Explorer之后，我们使用rundll32.exe来安装恶意代码，使用如下命令：

```
C:\Documents and Settings\Administrator\桌面\恶意代码\上机实验样本\Chapter_3L>ru
ndll32.exe Lab03-02.dll,installA
```

确保rundll32.exe已经终止后，使用Regshot工具做第二个快照，输出的Regshot结果如下

```
HKLMSYSTEM\ControlSet001\Services\IPRIP\EnumB: "Root\LEGACY_IPRIP\0000"
HKLMSYSTEM\ControlSet001\Services\IPRIP\EnumCount: 0x00000001
HKLMSYSTEM\ControlSet001\Services\IPRIP\EnumNextInstance: 0x00000001
HKLMSYSTEM\ControlSet001\Services\IPRIP\Security\Security: 01 00 14 80 90 00 00 00 9C 00 00 14 00 00 00 30 00 00 02 00 1C 00 01 00 00 02 80 14 00 FF 01 0F 00 01 01 00 00 00 00 01 00
HKLMSYSTEM\ControlSet001\Services\IPRIP\Parameters\ServiceDll: "C:\Documents and Settings\Administrator\桌面\恶意代码\上机实验样本\Chapter_3\Lab03-02.dll"
HKLMSYSTEM\ControlSet001\Services\IPRIP\Type: 0x00000000
HKLMSYSTEM\ControlSet001\Services\IPRIP\Start: 0x00000002
HKLMSYSTEM\ControlSet001\Services\IPRIP\ErrorControl: 0x00000001
HKLMSYSTEM\ControlSet001\Services\IPRIP\ImagePath: "%SystemRoot%\System32\svchost.exe -k netsvcs"
HKLMSYSTEM\ControlSet001\Services\IPRIP\DisplayName: "Intranet Network Awareness (INA+)"
HKLMSYSTEM\ControlSet001\Services\IPRIP\Description: "Depends INA+, Collects and stores network configuration and location information, and notifies applications when this information changes."
HKLMSYSTEM\ControlSet001\Services\IPRIP\DependOnService: "rpcss"
HKLMSYSTEM\CurrentControlSet\Enum\Root\LEGACY_IPRIP\0000\Control\NewlyCreated: 0x00000000
HKLMSYSTEM\CurrentControlSet\Enum\Root\LEGACY_IPRIP\0000\Control\ActiveService: "IPRIP"
HKLMSYSTEM\CurrentControlSet\Enum\Root\LEGACY_IPRIP\0000\Legacy: 0x00000001
HKLMSYSTEM\CurrentControlSet\Enum\Root\LEGACY_IPRIP\0000\ConfigFlags: 0x00000000
HKLMSYSTEM\CurrentControlSet\Enum\Root\LEGACY_IPRIP\0000\Class: "LegacyDriver"
```

1. 首先显示了恶意代码将自身安装为IPRIP服务，由于这个恶意代码是个DLL文件，它依赖于一个可执行文件来执行它。
2. 另外看到ImagePath被设置为svchost.exe，这意味着，这个恶意代码将会在一个svchost.exe进程中启动。
3. 另外信息包括DisplayName和Description，可以作为识别这个恶意服务的独特指纹特征。

已知上述信息，再次检查strings工具显示的字符串列表

```
%SystemRoot%\System32\svchost.exe -k netsvcs
OpenServiceManager<?
You specify service name not in Svchost\//netsvcs, must be one of following:
RegQueryValueEx(Svchost\netsvcs)
netsvcs
RegOpenKeyEx(%s) KEY_QUERY_VALUE success.
RegOpenKeyEx(%s) KEY_QUERY_VALUE error.
SOFTWARE\Microsoft\Windows NT\CurrentVersion\Svchost
IPRIP
uninstall success
OpenService(%s) error 2
OpenService(%s) error 1
uninstall is starting
.?AVtype_info@C
080C00^0m0r0
```

仔细地检查字符串列表，我们可以看到 SOFTWARE\Microsoft\windows

NT\CurrentVersion\SvcHost 和一个消息 You specify service name not in Svchost//netsvcs must be one of following。

检查 svchost//\Svchost\netsvcs 注册表项可以看到其他可能被使用的服务名称，比如 6to4 AppMgmt。运行 Lab03-02.dll，installA6to4 将安装恶意代码为6to4服务，而不再是前面所列出的 IPRIP服务。

以上即可作为该恶意代码在主机上的感染迹象特征。

运行恶意代码

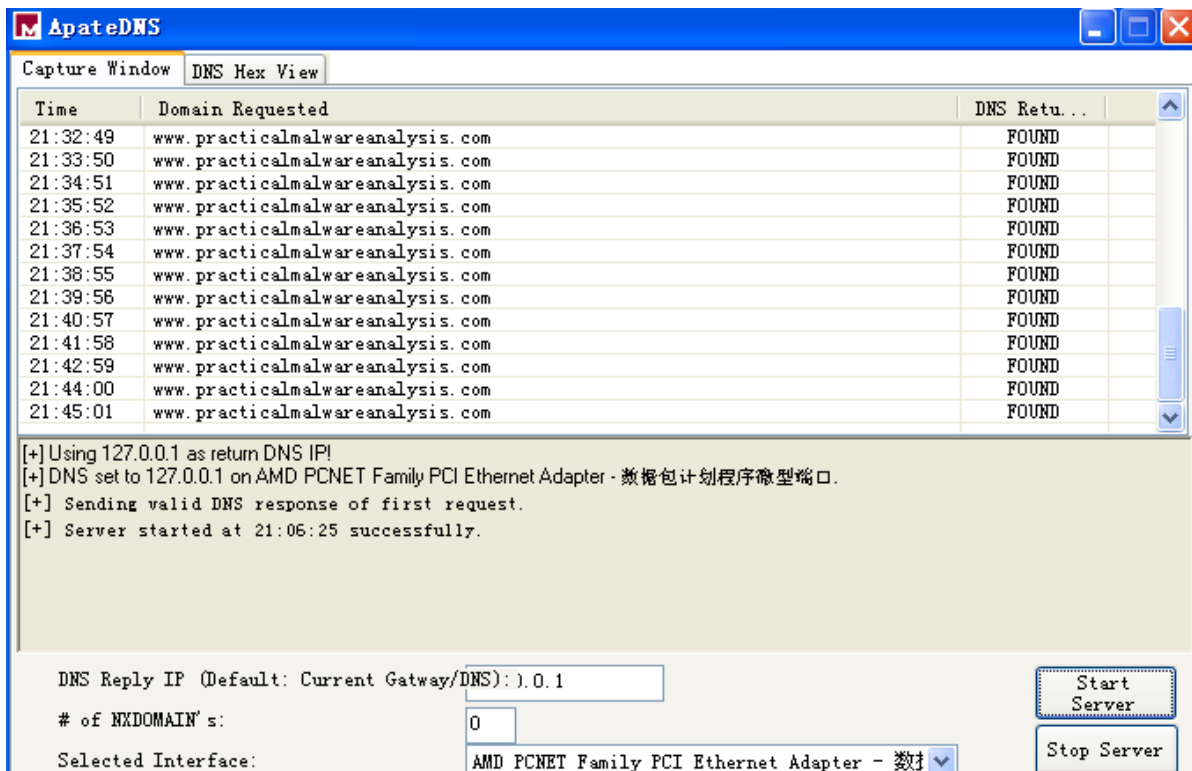
在将恶意代码安装为服务之后，就可以启动运行它了。在运行之前，首先需要配置动态分析基础技术工具。

- 运行procmon工具(并清除所有事件)，启动ProcessExplorer，以及配置一个虚拟网络，包括 ApateDNS、监听端口80的Netcat。

这个恶意代码安装为IPRIP服务，可以使用Windows中的net命令来启动

```
C:\Documents and Settings\Administrator\桌面\恶意代码\上机实验样本\Chapter_3L>net start IPRIP
Intranet Network Awareness (INA+) 服务正在启动 .
Intranet Network Awareness (INA+) 服务已经启动成功。
```

打开ProcessExplorer中，尝试寻找出恶意代码运行的进程，输入Lab03-02.dll进行Search。可以看到 Lab03-02.dll 是由 PID 为 1128 的 svchost.exe 进程加载的。



输出结果显示了一个向 practicalmalwareanalysis.com 的DNS请求，这也匹配到了静态分析得到的字符串列表。

最后分析Netcat的结果（在先前字符串列表中可以看到有HTTP，所以使用Netcat监听80端口）



可见恶意代码执行了一个通过80端口的HTTP GET 请求。多次运行这个测试，数据显示结果对每次运行都是一致的。

从这个数据可以创建出一组网络特征码。恶意代码始终发出一个对 serve.html 的GET请求，可以使用这个GET请求作为网络特征。

恶意代码也使用User-Agent为 dell-cdce31a6e0 windows XP6.11. dell-cdce31a6e0 是恶意代码分析虚拟机的名称，第二部分的User-Agent(windowsXP6.11)可以用来作为网络特征。

Lab03-03.exe

问题：

在一个安全的环境中执行Lab03-03.exe文件中发现的恶意代码，同时使用基础的动态行为分析工具监视它的行为。

1. 当你使用 Process Explorer 工具进行监视时，你注意到了什么？

恶意代码文件运行时创建了一个子进程，接着结束掉自己的进程，留下了之前创建的子进程独立运行，执行了对svchost.exe 文件的替换。

2. 你可以找出任何的内存修改行为吗？

对比内存映像与磁盘映像中的svchost.exe，显示它们并不是一样的。内存映像拥有如 practicalmalwareanalysis.log 和 [ENTER] 这样的字符串，而磁盘镜像中却没有。

3. 这个恶意代码在主机上的感染迹象特征是什么？

这个恶意代码创建了一个 practicalmalwareanalysis.log 日志文件

4. 这个恶意代码的目的是什么？

这个程序在 svchost.exe 进程上执行了进程替换，来启动一个击键记录器，将键盘键入的信息记录在了 practicalmalwareanalysis.log 文件中。

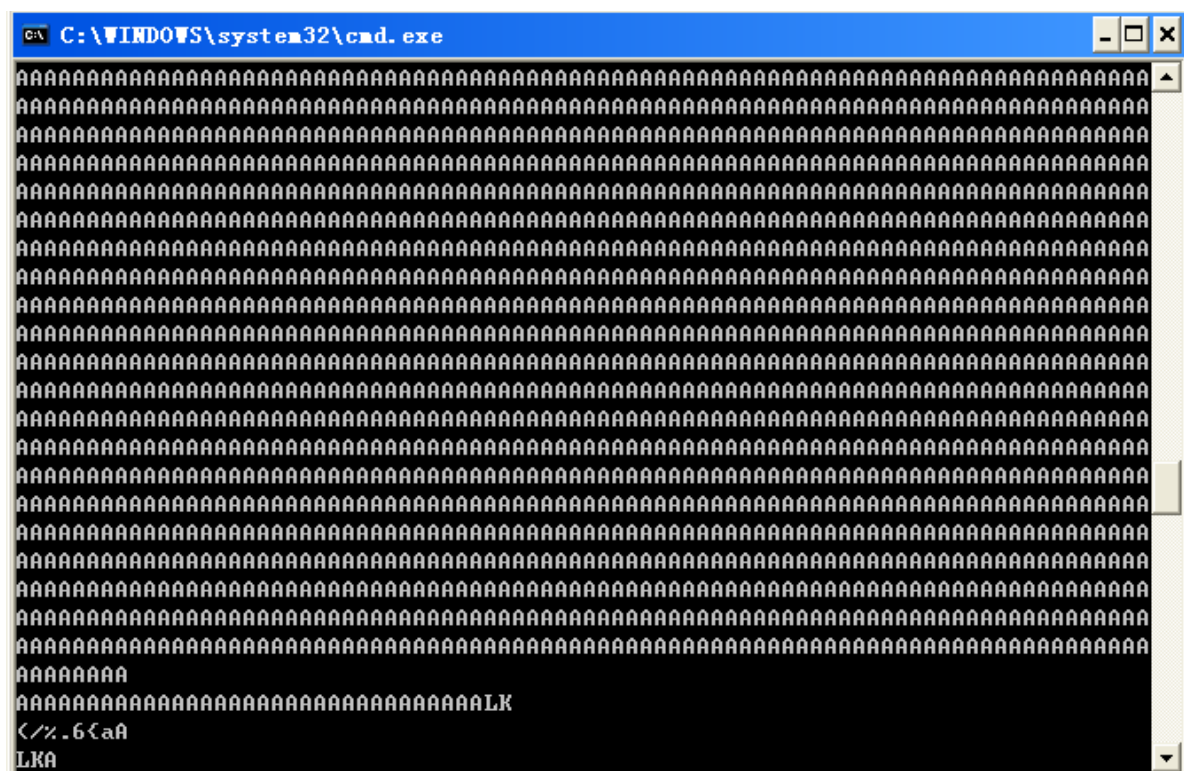
具体解析过程如下：

• 静态分析

使用PEiD工具查看该恶意代码，可以看到该恶意代码没有加壳迹象。



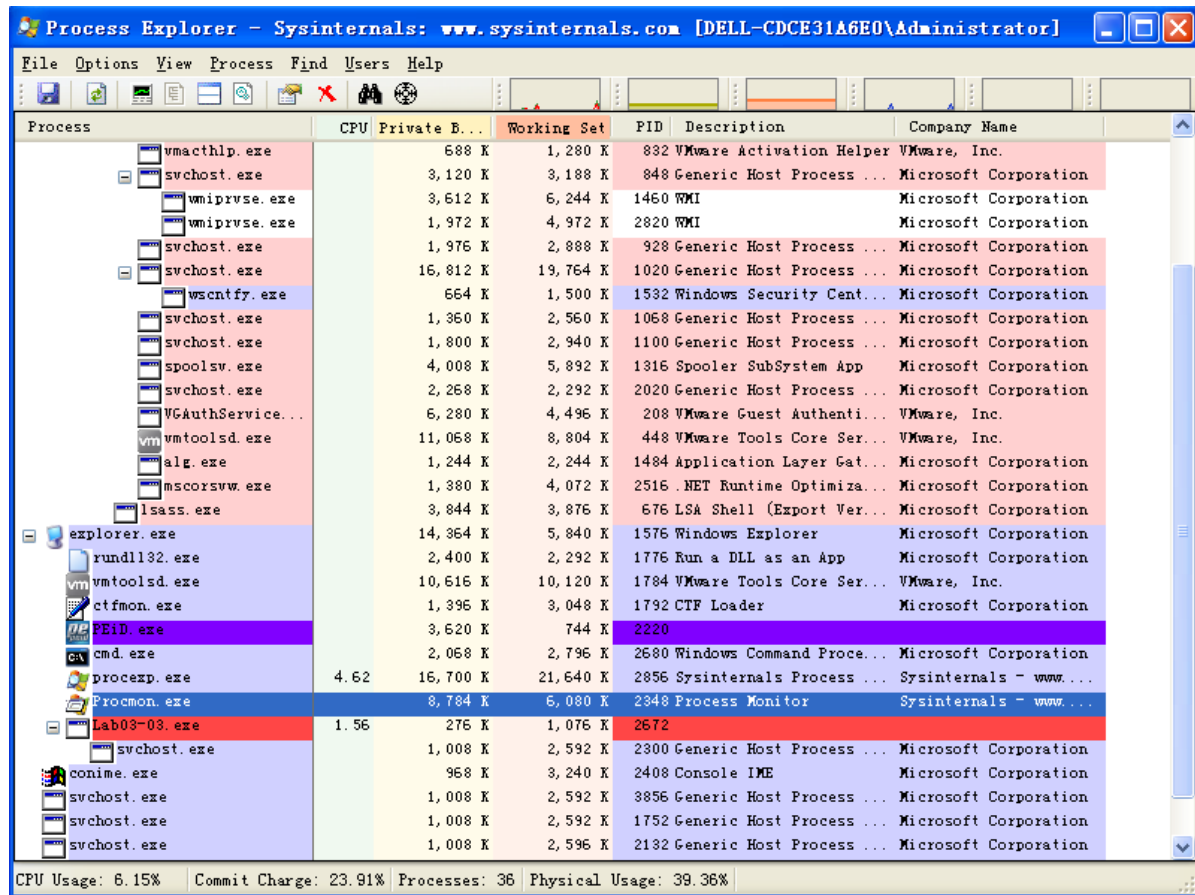
使用strings工具查看该恶意代码的字符串列表



可以发现，该文件中含有大量的字母A，这可以作为yara检测的一个规则。

• 动态分析

启动Process Explorer和Process Monitor监测工具进行动态检测。运行 Lab03-03.exe。

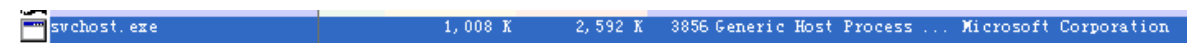


Process	CPU	Private B...	Working Set	PID	Description	Company Name
vmacthlp.exe		688 K	1,280 K	832	VMware Activation Helper	VMware, Inc.
svchost.exe		3,120 K	3,188 K	848	Generic Host Process ...	Microsoft Corporation
vmtoolsd.exe		3,612 K	6,244 K	1460	WMI	Microsoft Corporation
vmtoolsd.exe		1,972 K	4,972 K	2820	WMI	Microsoft Corporation
svchost.exe		1,976 K	2,888 K	928	Generic Host Process ...	Microsoft Corporation
svchost.exe		16,812 K	19,764 K	1020	Generic Host Process ...	Microsoft Corporation
wscntfy.exe		664 K	1,500 K	1532	Windows Security Cent...	Microsoft Corporation
svchost.exe		1,360 K	2,560 K	1068	Generic Host Process ...	Microsoft Corporation
svchost.exe		1,800 K	2,940 K	1100	Generic Host Process ...	Microsoft Corporation
spoolsv.exe		4,008 K	5,892 K	1316	Spooler SubSystem App	Microsoft Corporation
svchost.exe		2,268 K	2,292 K	2020	Generic Host Process ...	Microsoft Corporation
VGAuthService.exe		6,280 K	4,496 K	208	VMware Guest Authent...	VMware, Inc.
vmtoolsd.exe		11,068 K	8,804 K	448	VMware Tools Core Ser...	VMware, Inc.
alg.exe		1,244 K	2,244 K	1484	Application Layer Gat...	Microsoft Corporation
mscorsvw.exe		1,380 K	4,072 K	2516	.NET Runtime Optimiza...	Microsoft Corporation
lsass.exe		3,844 K	3,876 K	676	LSA Shell (Export Ver...	Microsoft Corporation
explorer.exe		14,364 K	5,840 K	1576	Windows Explorer	Microsoft Corporation
rundll32.exe		2,400 K	2,292 K	1776	Run a DLL as an App	Microsoft Corporation
vmtoolsd.exe		10,616 K	10,120 K	1784	VMware Tools Core Ser...	VMware, Inc.
ctfmon.exe		1,396 K	3,048 K	1792	CTF Loader	Microsoft Corporation
PEiD.exe		3,620 K	744 K	2220		
cmd.exe		2,068 K	2,796 K	2680	Windows Command Proce...	Microsoft Corporation
proccp.exe	4.62	16,700 K	21,640 K	2856	Sysinternals Process ...	Sysinternals - www...
Procmon.exe		8,784 K	6,080 K	2348	Process Monitor	Sysinternals - www...
Lab03-03.exe	1.56	276 K	1,076 K	2672		
svchost.exe		1,008 K	2,592 K	2300	Generic Host Process ...	Microsoft Corporation
conime.exe		968 K	3,240 K	2408	Console IME	Microsoft Corporation
svchost.exe		1,008 K	2,592 K	3856	Generic Host Process ...	Microsoft Corporation
svchost.exe		1,008 K	2,592 K	1752	Generic Host Process ...	Microsoft Corporation
svchost.exe		1,008 K	2,596 K	2132	Generic Host Process ...	Microsoft Corporation

CPU Usage: 6.15% Commit Charge: 23.91% Processes: 36 Physical Usage: 39.36%

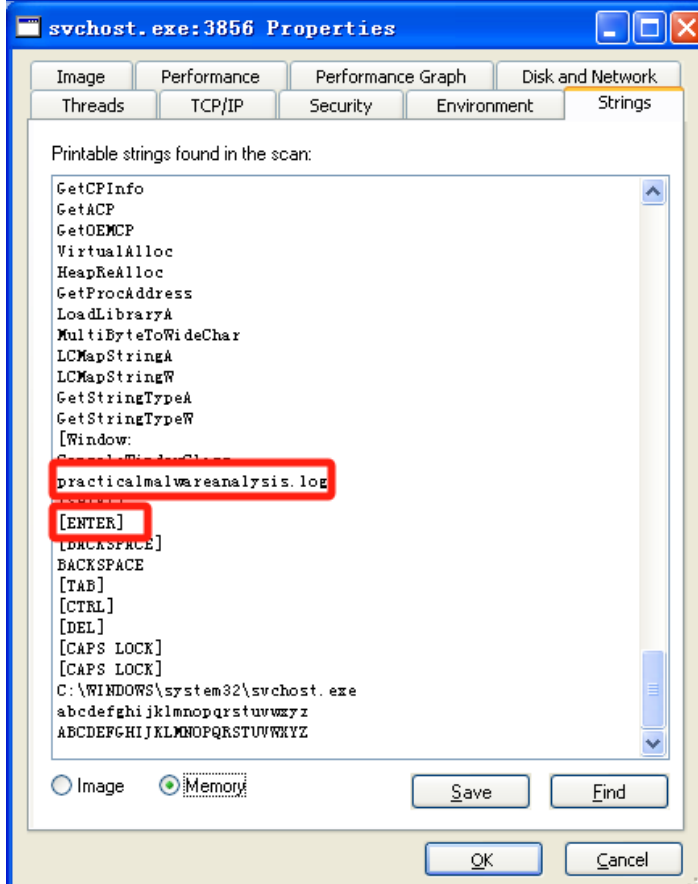
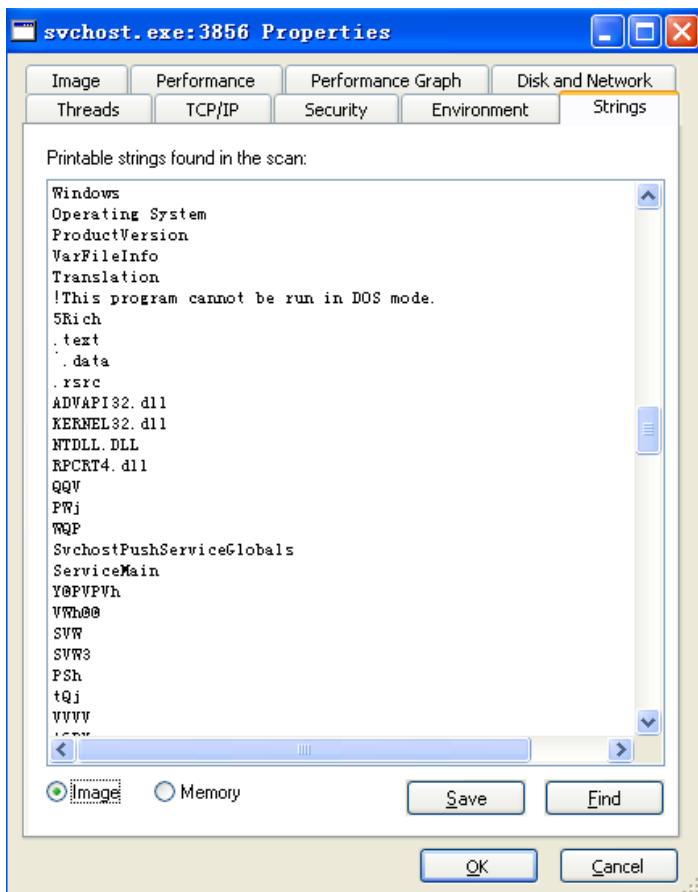
观察Process Explorer，可以看到，该文件除创建自己的进程外，还创建了一个子进程 `svchost.exe`，创建后 `Lab03-03.exe` 自行退出，仅剩子进程 `svchost.exe` 独立运行。

查看 `svchost.exe` 进程的属性



Process	CPU	Private B...	Working Set	PID	Description	Company Name
svchost.exe		1,008 K	2,592 K	3856	Generic Host Process ...	Microsoft Corporation

这个进程看起来像是一个PID为3856的合法 `svchost.exe` 进程，但这个 `svchost.exe` 是很可疑的，因为 `svchost.exe` 通常是 `services.exe` 的子进程。



从这个相同的属性页面中，选择Strings查看在磁盘镜像中和内存镜像中可执行文件的字符串列表。通过在Image和Memory单选按钮之间切换，可以看出两者镜像中的显著差异。

右侧图中内存镜像中的字符串列表里包含了 practicalmalwareanalysis.log 和 [ENTER]，而它们都不会在磁盘镜像中一个典型的svchos.exe文件中出现，如左侧图中所示。

practicalmalwareanalysis.log 字符串的存在，再加上出现了 [ENTER] 和 [CAPS LOCK] 这样的字符串，表明这个程序很可能是一个击键记录器。



使用strings工具查看该恶意代码的字符串列表

```

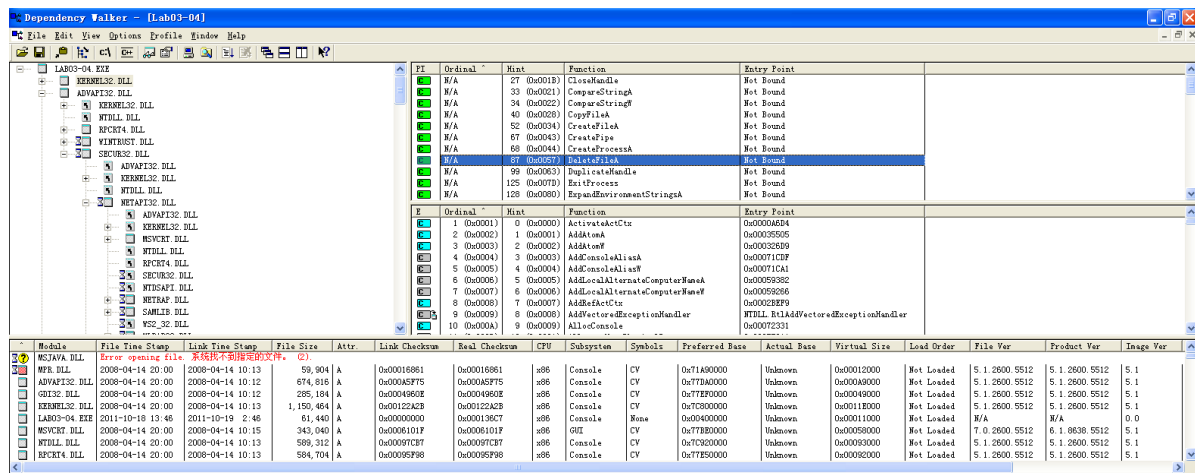
C:\WINDOWS\system32\cmd.exe
LCMapStringW
GetProcAddress
LoadLibraryA
FlushFileBuffers
GetFileAttributesA
CreateProcessA
CompareStringA
CompareStringW
SetEnvironmentVariableA
lZQ
Configuration
SOFTWARE\Microsoft \XPS
\kernel32.dll
HTTP/1.0
GET
' ' ' '
' ' ' '
NOTHING
CMD
DOWNLOAD
UPLOAD
SLEEP
cmd.exe
>> NUL
/c del
ups
http://www.practicalmalwareanalysis.com
Manager Service
.exe
%SYSTEMROOT%\system32\
k:%s h:%s p:%s per:%s
-cc
-re
-in
PST
PDT

```

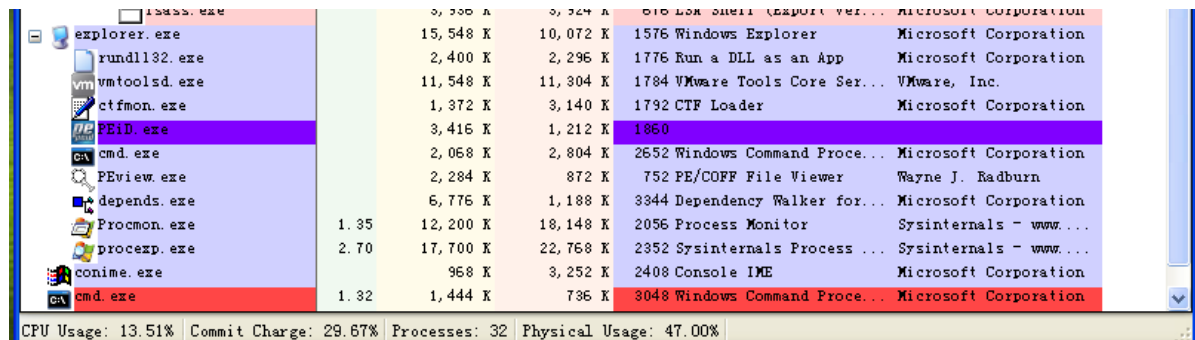
可见域名、注册表位置(如字符串 SOFTWARE\Microsoft \XPS 像 DOWNLOAD、UPLOAD 这样的命令字符串，以及 HTTP/1.0 字符串等。这些表明恶意代码可能是一个HTTP后门程序。字符串 -cc、-re、-in 应该是一些命令行参数(例如 -in 可能是install的缩写)。

• 动态分析

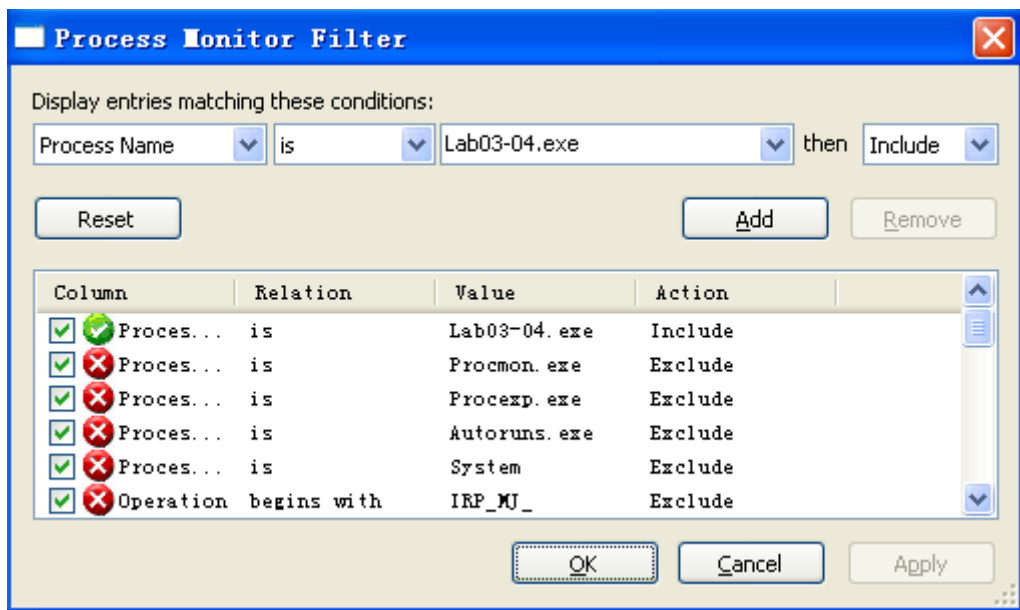
使用DependencyWalker打开该文件看到这个恶意代码导入了一些联网功能函数、服务操作函数和注册表操作函数，如DeleteFile和ShellExecute等可疑函数。



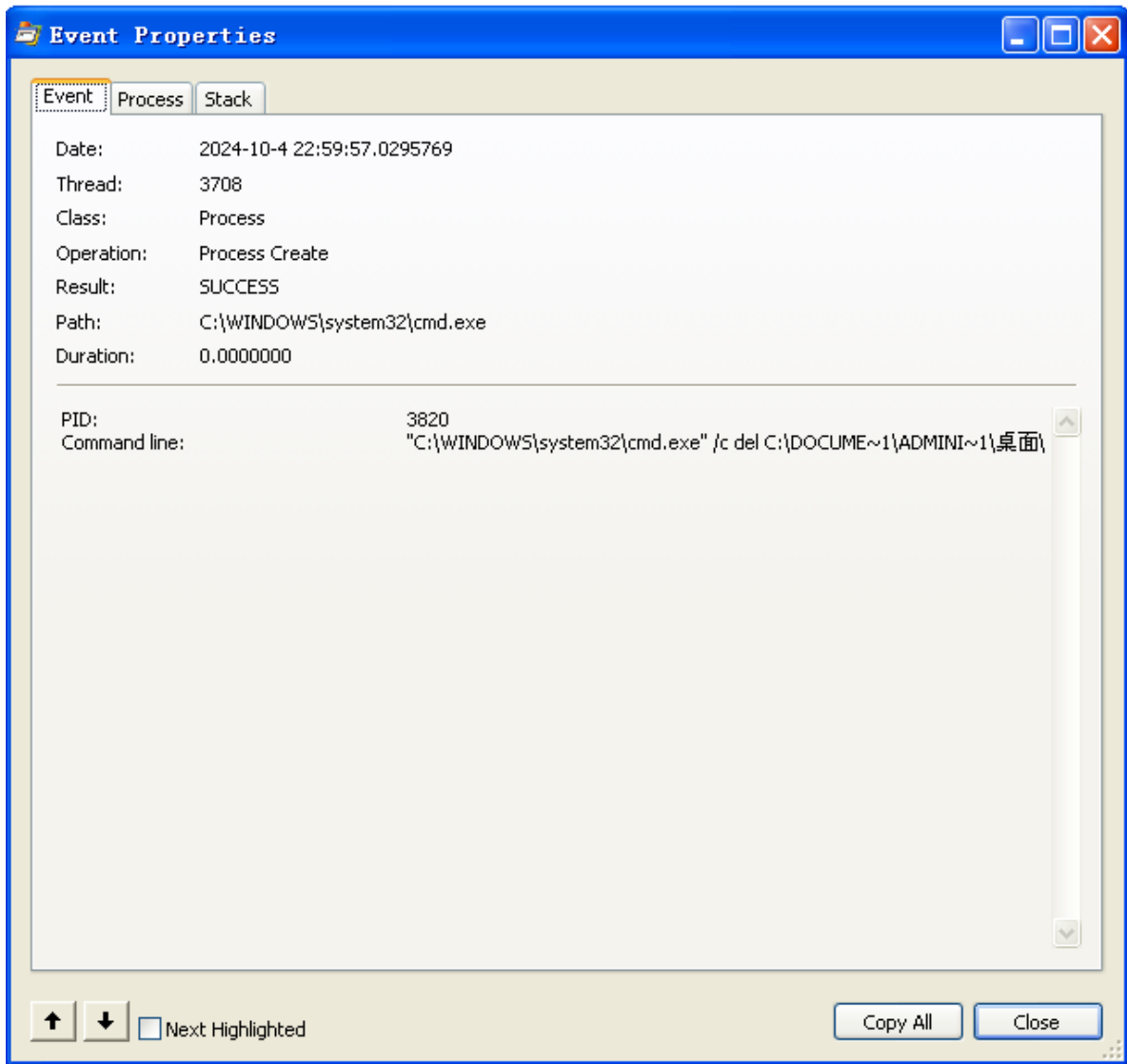
运行恶意代码之前，运行procmon工具并清除所有事件，启动Process Explorer，并设置一个虚拟网络。当运行 Lab03-04.exe，只出现一个cmd进程，可以看到几秒后，文件消失了，打开回收站可以看到刚才打开的文件，该恶意代码似乎立即删除了自身，在Process Explorer中没有观察到特殊行为。



在Process Monitor中添加过滤规则 Process Name is Lab03-04.exe，可以看到与该文件有关的操作。经过分析可以看到，恶意代码执行了与文件或是注册表相关的操作。



没有获得如WriteFile、RegSetValue之类的事件，但是通过深入挖掘后，发现了一个ProcessCreate的条目。查看该条目属性可以看到，恶意代码是通过使用 "C:\WINDOWS\system32\cmd.exe"/c del Z:\Lab03-04.exe>>NUL 来从系统中删去自身的。



四、Yara规则

基于上述分析，借助yargen工具，编写得到如下yara规则：

```
rule Lab03_01 {
  meta:
    description = "Lab03-01.exe"
  strings:
    $s1 = "vmx32to64.exe" fullword ascii
    $s2 = "SOFTWARE\\Classes\\http\\shell\\open\\commandV" fullword ascii
    $s3 = " www.practicalmalwareanalysis.com" fullword ascii
    $s4 = "CONNECT %s:%i HTTP/1.0" fullword ascii
    $s5 = "advpack" fullword ascii
    $s6 = "VideoDriver" fullword ascii
    $s7 = "AppData" fullword ascii /* Goodware String - occurred 74 times */
    $s8 = "6I*h<8" fullword ascii /* Goodware String - occurred 1 times */
    $s9 = "StubPath" fullword ascii /* Goodware String - occurred 1 times */
    $s10 = "winVMX32-" fullword ascii
    $s11 = "Software\\Microsoft\\Active Setup\\Installed Components\\"
    fullword ascii /* Goodware String - occurred 4 times */
    $s12 = "^-m-m<|<|<|M" fullword ascii
  condition:
    uint16(0) == 0x5a4d and filesize < 20KB and 8 of them
}
```

```

}

rule Lab03_02 {
  meta:
    description = "Lab03-02.dll"
  strings:
    $x1 = "%SystemRoot%\System32\svchost.exe -k " fullword ascii
    $x2 = "cmd.exe /c " fullword ascii
    $s3 = "RegOpenKeyEx(%s) KEY_QUERY_VALUE error ." fullword ascii
    $s4 = "Lab03-02.dll" fullword ascii
    $s5 = "practicalmalwareanalysis.com" fullword ascii
    $s6 = "RegOpenKeyEx(%s) KEY_QUERY_VALUE success." fullword ascii
    $s7 = "GetModuleFileName() get dll path" fullword ascii
    $s8 = "dw5zdXBwb3J0" fullword ascii /* base64 encoded string 'unsupport'
  */
    $s9 = "Y29ubmVjda==" fullword ascii /* base64 encoded string 'connect' */
    $s10 = "OpenService(%s) error 2" fullword ascii
    $s11 = "OpenService(%s) error 1" fullword ascii
    $s12 = "CreateService(%s) error %d" fullword ascii
    $s13 = "You specify service name not in svchost//netsvcs, must be one of
following:" fullword ascii
    $s14 = "RegQueryValueEx(Svchost\netsvcs)" fullword ascii
    $s15 = "netsvcs" fullword ascii
    $s16 = "serve.html" fullword ascii
    $s17 = "DependOnService" fullword ascii
    $s18 = "::$:K:U:\\:l:" fullword ascii
    $s19 = "uninstall is starting" fullword ascii
    $s20 = "uninstall success" fullword ascii
  condition:
    uint16(0) == 0x5a4d and filesize < 70KB and 1 of ($x*) and 4 of them
}

rule Lab03_03 {
  meta:
    description = "Lab03-03.exe"
  strings:
    $s1 = "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s2 =
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s3 =
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s4 =
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAA" ascii
    $s5 =
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s6 = "aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa" ascii
    $s7 = "\\svchost.exe" fullword ascii
    $s8 = "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s9 =
"BAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s10 = "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s11 = "AAAAABAAAA" ascii

```



```

    $s12 =
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s13 = "AAaQAAApAAASAAARAAAUAAAtAAAWAAAVAAAYAAAXAAA" fullword ascii
    $s14 =
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA" ascii
    $s15 =
"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAq"
fullword ascii
    $s16 = "wqpWLKlA/.5a$/.4&)a2l \" $a'.3a5)3$ %a% 5 LKALK #/.3, -a13.&3
,a5$3,(/ 5(/LKAAAA" fullword ascii
    $s17 = "- 22AA13 \"5(\" -, -6 3$ / -82(2o-.&AAAAaAAA" fullword ascii
    $s18 = "+A+A+A+A" fullword ascii /* reversed goodwill string 'A+A+A+A+' */
    $s19 = "(\"3.2.'5a" fullword ascii /* hex encoded string '2Z' */
    $s20 = "wqswLKlA/.5a$/.4&)a2l \" $a'.3a25%(a/(5( -(; 5(/LKAAAA" fullword
ascii
    condition:
        uint16(0) == 0x5a4d and filesize < 200KB and 8 of them
}

rule Lab03_04 {
    meta:
        description = "Lab03-04.exe"
    strings:
        $s1 = "http://www.practicalmalwareanalysis.com" fullword ascii
        $s2 = "%SYSTEMROOT%\\system32\\" fullword ascii
        $s3 = " HTTP/1.0" fullword ascii
        $s4 = " Manager Service" fullword ascii
        $s5 = "UPLOAD" fullword ascii /* Goodware String - occurred 1 times */
        $s6 = "DOWNLOAD" fullword ascii /* Goodware String - occurred 26 times */
        $s7 = "command.com" fullword ascii /* Goodware String - occurred 55 times
*/
        $s8 = "COMSPEC" fullword ascii /* Goodware String - occurred 140 times */
        $s9 = "\"wSh(" fullword ascii /* Goodware String - occurred 1 times */
        $s10 = "SOFTWARE\\Microsoft \\XPS" fullword ascii
        $s11 = "k:%s h:%s p:%s per:%s" fullword ascii
        $s12 = " >> NUL" fullword ascii
        $s13 = "/c del " fullword ascii
        $s14 = "6KRich" fullword ascii
    condition:
        uint16(0) == 0x5a4d and filesize < 200KB and 8 of them
}

```

检测结果如下

```

PS D:\deskbook\Malware\Chapter_3L> .\yara64.exe -r -c .\Lab3.yar .
.\Lab03-01.exe: 1
.\Lab03-02.dll: 1
.\Lab03-04.exe: 1
.\Lab3.yar: 0
.\yara64.exe: 0
.\Lab03-03.exe: 1

```

成功检出 Lab03-01.exe Lab03-02.dll Lab03-03.exe Lab03-04.exe 。

五、实验结论及心得体会

1. 实验过程中遇到的部分问题

(1) windowsXP中的apateDNS不能正常运行，会显示应用程序正常初始化失败



需要另外下载 .NET framework，在更高级的windows操作系统中是可以自动查询缺失文件进行加载，而在WindowsXP中需要自主下载安装包，同时还需注意下载版本兼容问题。

(2) 在Win10上进行恶意代码分析时，发现其有些分析结果与xp操作系统上不同，包括一些字符串列表输出以及网络感染的特征都会有些不同。这主要是由于两个操作系统在架构设计、安全机制、更新策略以及用户交互方式等多个方面存在显著区别。Win10采用了更为现代化和安全的架构设计，包括增强的内核保护、更严格的权限管理和更完善的内存管理机制，这些改进使得Win10在抵御恶意代码攻击方面表现出更强的能力。初步接触恶意代码分析之后在进行恶意代码分析时还是使用WindowsXP操作系统，可以观察到完整稳定的恶意代码执行过程和执行目的。

(3) WinVMX32 的互斥量：

互斥量（Mutex）是一种同步机制，用于防止多个线程或进程同时访问共享资源。恶意软件创建互斥量通常是为了确保只有一个实例在运行，避免重复执行或资源冲突。WinVMX32 可能是这个恶意软件用来标识自己或确保唯一性的名称。

(4) Netcat监听端口

80端口和443端口是网络通信中常用的两个端口，它们之间有几个关键的区别：

80端口：

- **协议：**用于HTTP（HyperText Transport Protocol，超文本传输协议）通信。
- **用途：**主要用于传输未加密的网页数据。当你在浏览器中输入一个网址并访问网站时（如果网址以“http://”开头），通常是通过80端口进行通信的。

443端口：

- **协议：**用于HTTPS（HyperText Transport Protocol Secure，安全超文本传输协议）通信。HTTPS是在HTTP基础上加入了SSL/TLS加密层，用于确保数据在客户端和服务端之间的传输是安全的。
- **用途：**主要用于传输加密的网页数据，以保护用户隐私和数据安全。几乎所有使用HTTPS协议的网站（网址以“https://”开头）都是通过443端口进行通信的。

2. 心得体会

在本次实验中，更完整的了解了ProcessExplorer、ProcessMonitor等分析工具的使用方法，初步掌握了动态分析恶意代码的方法。

可以看到不同的恶意代码的隐藏技术的多样性以及在主机上的不同感染迹象特征的差异。